

MODULO 1

Cultura y Etica– Clase 4

José Lagos Melo, PhD, CISM, CISA, CDPSE

Objetivos del Curso



Comprender la cultura organizacional

Exploraremos el enfoque de Edgar Schein para entender los niveles de la cultura organizacional y su impacto en la protección de datos.



Identificar comportamientos

Aprenderemos a reconocer comportamientos deseados y no deseados relacionados con la protección de datos en el entorno laboral.



Aplicar metodologías

Implementaremos metodologías efectivas para el cambio de comportamiento y mediremos la madurez cultural de la organización.



Diseñar un plan de acción

Desarrollaremos un plan de cambio cultural con acciones específicas por cluster y resolveremos un caso práctico tipo taller.



¿Por qué cultura en protección de datos?

80%

Errores humanos

De los incidentes de seguridad de datos provienen de errores humanos, no de fallas técnicas.

100%

Cumplimiento legal

La ley exige cumplimiento total, pero solo una cultura sólida garantiza sostenibilidad a largo plazo.

360°

Enfoque integral

La privacidad no es solo un asunto técnico, sino también organizacional y ético que requiere un abordaje completo.

Crear una cultura de protección de datos no es opcional en el entorno actual. Las organizaciones deben ir más allá del cumplimiento normativo para integrar la privacidad como un valor fundamental en cada nivel de operación.

Cultura según Edgar Schein



Según Edgar Schein, la cultura organizacional es un conjunto de supuestos compartidos que un grupo ha aprendido a medida que resuelve sus problemas. Estos supuestos funcionan lo suficientemente bien como para ser considerados válidos y, por tanto, son enseñados a los nuevos miembros como la forma correcta de percibir, pensar y sentir en relación con esos problemas.

Niveles de la cultura



Artefactos

Elementos visibles como carteles, lenguaje y políticas



Valores declarados

Lo que se promueve oficialmente en la organización

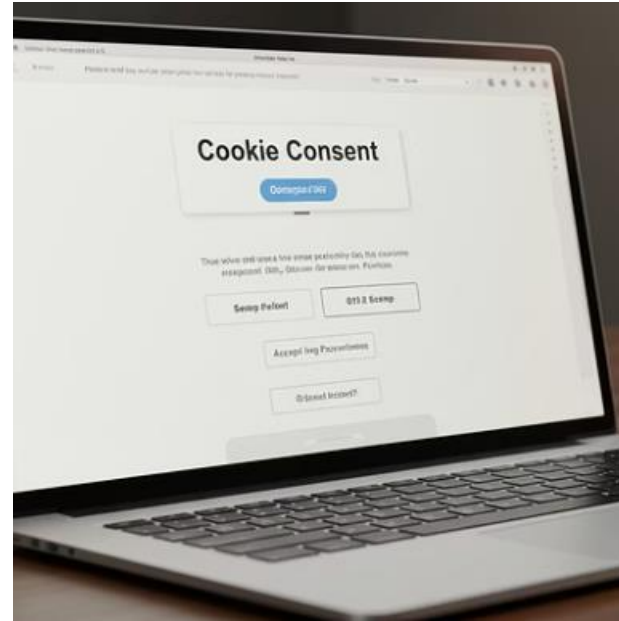


Supuestos básicos

Lo que realmente se cree y se hace en la práctica

Los tres niveles de la cultura organizacional interactúan constantemente. Mientras que los artefactos son fácilmente observables, los supuestos básicos son difíciles de identificar y cambiar. El desafío en protección de datos es alinear estos tres niveles para crear una cultura coherente donde lo que se dice coincida con lo que realmente se hace.

Ejemplos de artefactos



Los artefactos son los elementos más visibles de la cultura organizacional en protección de datos. Incluyen **las políticas de privacidad publicadas** que establecen compromisos formales, los banners de consentimiento que interactúan con usuarios, los posters internos que promueven la concienciación, y los formularios con cláusulas claras que facilitan la transparencia.

Estos elementos tangibles son la primera capa de la cultura y, aunque importantes, deben estar respaldados por valores y supuestos coherentes para ser realmente efectivos en la protección de datos.



Stupe
**PRIVACY &
PRIVACY**

Coniency
**DATA
PROTOECTION**
Consare Laers
ConTERS alic uase

Ejemplos de valores declarados

"La privacidad es un derecho"

Este valor establece el compromiso de la organización con el respeto fundamental a la privacidad de las personas, reconociéndola como un derecho inherente que debe ser protegido en todas las operaciones y decisiones.

"Los datos personales son parte de nuestra reputación"

Este valor vincula la gestión adecuada de datos con la imagen corporativa, enfatizando que el manejo responsable de la información personal impacta directamente en la confianza y percepción pública de la organización.

"Nuestro compromiso es cuidar los datos de nuestros clientes"

Este valor destaca la responsabilidad activa que asume la organización en la protección de los datos que le han sido confiados, estableciendo una promesa de custodia diligente.

Supuestos inconscientes comunes



"La privacidad es solo responsabilidad de TI"

Este supuesto erróneo delega toda la responsabilidad de protección de datos al departamento técnico, ignorando que la privacidad es una responsabilidad compartida por todos los miembros de la organización, independientemente de su rol o función.



"No pasa nada si comparto esta base interna"

Este supuesto minimiza los riesgos asociados con compartir información sensible, subestimando las posibles consecuencias legales, reputacionales y de seguridad que pueden derivarse de estas acciones aparentemente inofensivas.



"Si nadie lo nota, no es un problema"

Este supuesto peligroso prioriza la apariencia sobre la integridad, fomentando una cultura de ocultamiento que puede magnificar los daños de incidentes no reportados y atendidos oportunamente.

Comportamientos deseados



Reportar incidentes de seguridad

Comunicar inmediatamente cualquier brecha o sospecha de vulneración de datos personales a través de los canales establecidos, sin temor a represalias y con la convicción de que contribuye a la protección colectiva.



Validar identidad de usuarios

Verificar rigurosamente la identidad de las personas antes de proporcionar acceso o información, siguiendo los protocolos establecidos y sin ceder ante presiones de urgencia o familiaridad.



No compartir claves de acceso

Mantener la confidencialidad de las credenciales personales, entendiendo que son intransferibles y que su protección es fundamental para la seguridad de toda la información organizacional.



Acceder solo a los datos necesarios

Aplicar el principio de mínimo privilegio, consultando únicamente la información estrictamente necesaria para el desempeño de las funciones asignadas.

Comportamientos no deseados

Fotografiar pantallas con datos

Capturar imágenes de información sensible en pantallas, creando copias no controladas que pueden ser fácilmente compartidas o extraviadas.

Hablar de clientes en espacios públicos

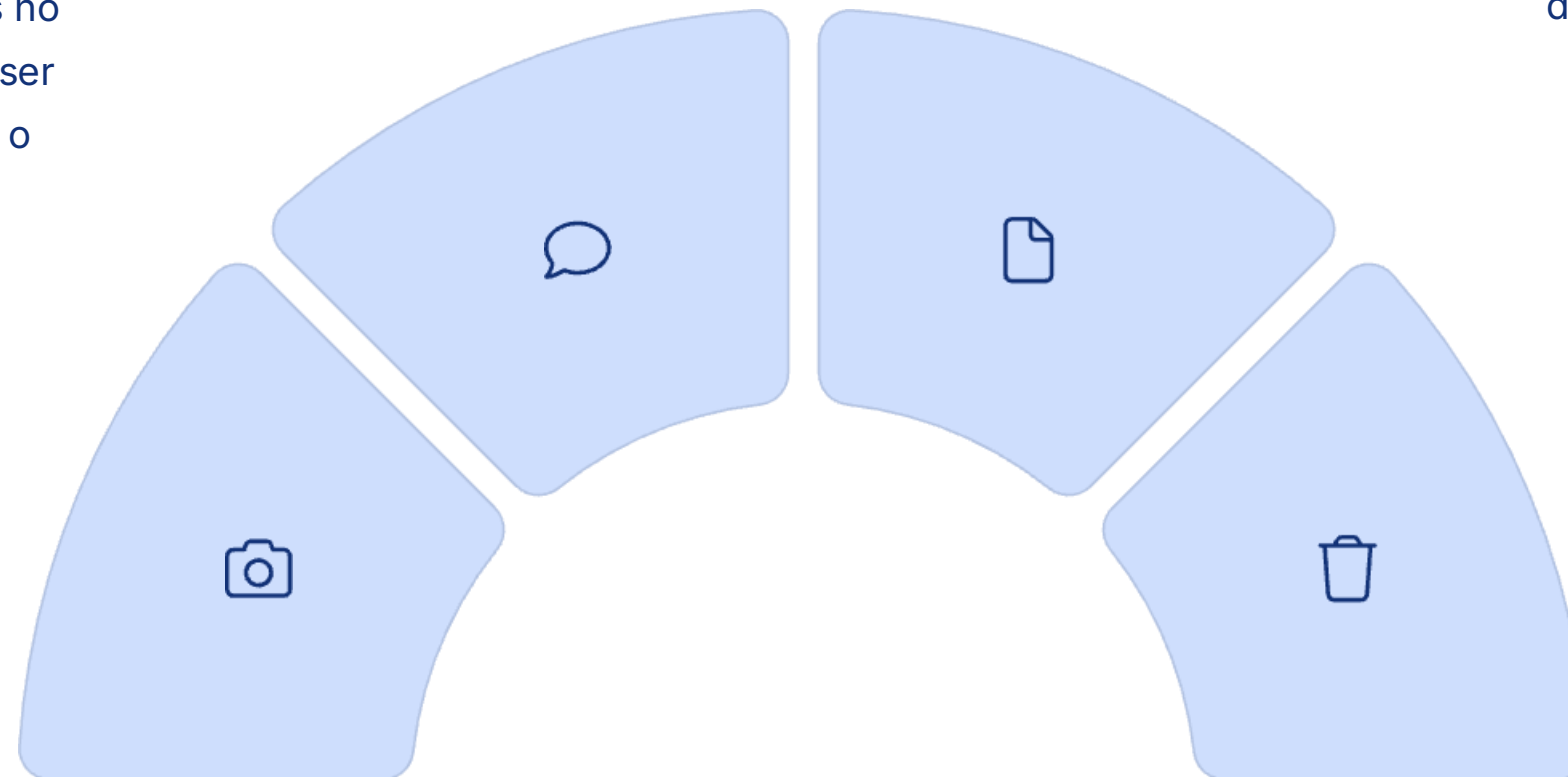
Discutir información confidencial de clientes en lugares donde terceros pueden escuchar, comprometiendo la privacidad sin dejar evidencia tangible.

Enviar bases sin cifrado

Transmitir datos personales sin las medidas de seguridad adecuadas, exponiéndolos a posibles interceptaciones o accesos no autorizados.

Ignorar procedimientos de eliminación

Desechar documentos o dispositivos con información sensible sin seguir los protocolos de destrucción segura establecidos.



Building a Culture of Privacy: A Behavioral Checklist



BEHAVIOR 1: La privacidad se practica en las operaciones diarias.

BEHAVIOR 2: Las personas respetan la importancia de las políticas y principios de privacidad.

BEHAVIOR 3: Se proporciona a las personas una orientación de privacidad suficiente y detallada y se les anima a participar y desafiar las prácticas de privacidad actuales.

BEHAVIOR 4: Todos son responsables de la protección de la información dentro de la empresa.

BEHAVIOR 5: Las partes interesadas saben cómo identificar y responder a las amenazas a la empresa.

BEHAVIOR 6: La dirección apoya y anticipa de forma proactiva las nuevas innovaciones en materia de privacidad y lo comunica a la empresa. La empresa es receptiva a considerar y hacer frente a los nuevos cambios de seguridad de la información

BEHAVIOR 7: La gestión empresarial se involucra en una colaboración continua e interfuncional para permitir programas de gestión de privacidad eficientes y efectivos.

BEHAVIOR 8: La dirección ejecutiva reconoce el valor empresarial de la privacidad.

Diferencias entre cultura declarada vs. real

Cultura Declarada

"Aquí respetamos la privacidad"

- Políticas formales de protección de datos
- Capacitaciones periódicas documentadas
- Certificaciones y sellos de privacidad
- Comunicados sobre la importancia de la confidencialidad

Cultura Real

"Yo dejo la pantalla desbloqueada porque es más cómodo"

- Contraseñas compartidas entre compañeros
- Documentos sensibles olvidados en impresoras
- Bases de datos enviadas por correo sin protección
- Incidentes no reportados por temor a consecuencias

La brecha entre lo que una organización dice valorar y lo que realmente practica representa uno de los mayores desafíos en la construcción de una cultura sólida de protección de datos. Esta disonancia no solo compromete la seguridad de la información, sino que también erosiona la confianza interna y externa.

Modelo ADKAR – Introducción



El modelo ADKAR proporciona un marco estructurado para guiar el cambio individual, reconociendo que la transformación organizacional comienza con cada persona. Este enfoque secuencial aborda las barreras psicológicas y prácticas que suelen obstaculizar la adopción de nuevos comportamientos en protección de datos.

ADKAR – Ejemplo práctico

Awareness



Objetivo: Que comprendan por qué es importante eliminar correctamente los datos.

Acciones:

- Campaña de sensibilización con casos reales (por ejemplo, fuga de datos por archivos mal eliminados).
- Video corto con testimonio de un CISO: "Cómo un archivo mal gestionado comprometió a toda la organización".
- Infografía que muestre los riesgos legales y reputacionales.

Frase clave: "Lo que no eliminas bien, puede eliminar tu reputación".



Desire

Objetivo: Motivar al colaborador a querer adoptar el nuevo comportamiento.

Acciones:

- Reconocimiento público a equipos que aplican buenas prácticas.
- Mostrar cómo eliminar datos correctamente les evita riesgos personales y responsabilidades legales.
- Vincular el cambio con los valores de la empresa (ética, respeto, confianza).

Frase clave: "Cuidar los datos es cuidar tu trabajo y a tus compañeros".



ADKAR – Ejemplo práctico

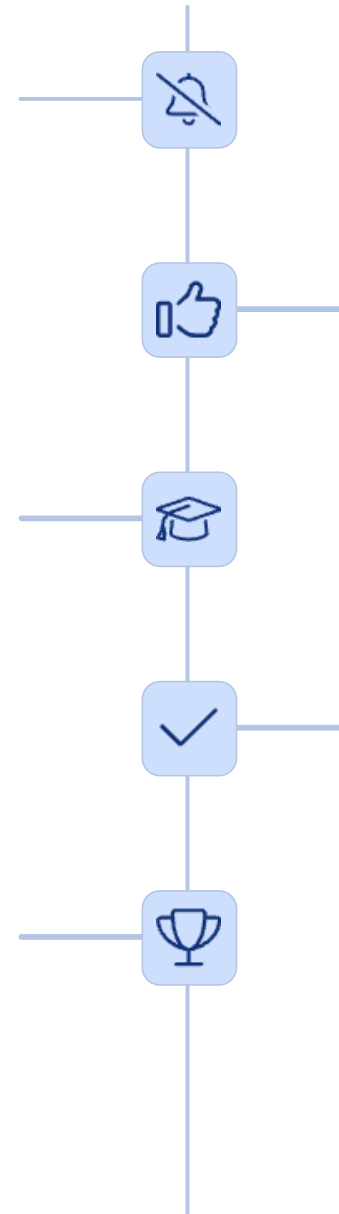
Knowledge

Objetivo: Enseñar cómo hacerlo.

Acciones:

- Taller práctico de 30 minutos: "Cómo eliminar archivos de forma segura en tu unidad de red".
- Manual visual paso a paso: borrar + limpiar papelera + política de retención de datos.
- Simulación con ejemplo real: eliminar datos personales obsoletos de una planilla compartida.

Frase clave: "Saber cómo hacerlo es la mitad del trabajo bien hecho".



Ability

Objetivo: Que puedan aplicar lo aprendido en su rutina diaria.

Acciones:

- Habilitar botón de "borrado seguro" en carpetas compartidas (integración con TI).
- Acompañamiento por parte del DPO o champion de datos durante 2 semanas.
- Medición de desempeño: revisión aleatoria de carpetas compartidas.

Frase clave: "Con las herramientas y apoyo correctos, tú puedes".

ADKAR – Ejemplo práctico

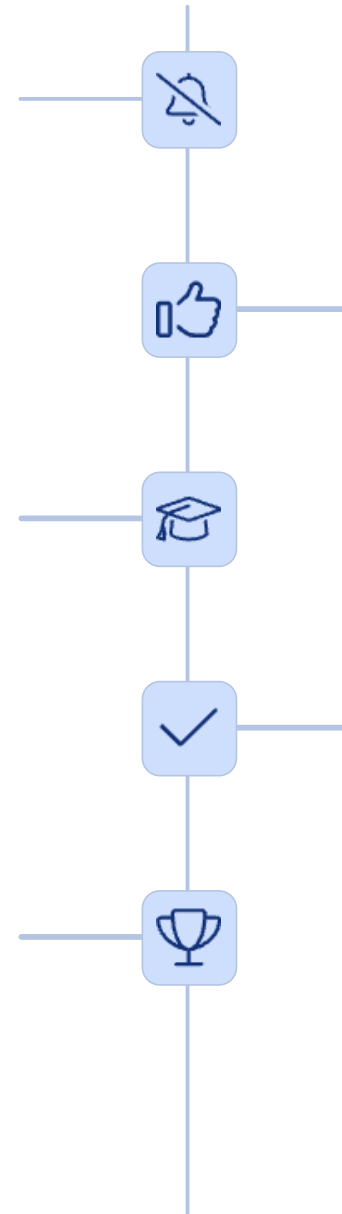
Reinforcement

Objetivo: Que el comportamiento se mantenga en el tiempo.

Acciones:

- Retroalimentación mensual con reporte de cumplimiento por área.
- Gamificación: ranking de equipos con mejor manejo de datos.
- Correos mensuales con tips y casos de éxito.

Frase clave: "Cada acción cuenta: tu compromiso protege a todos".

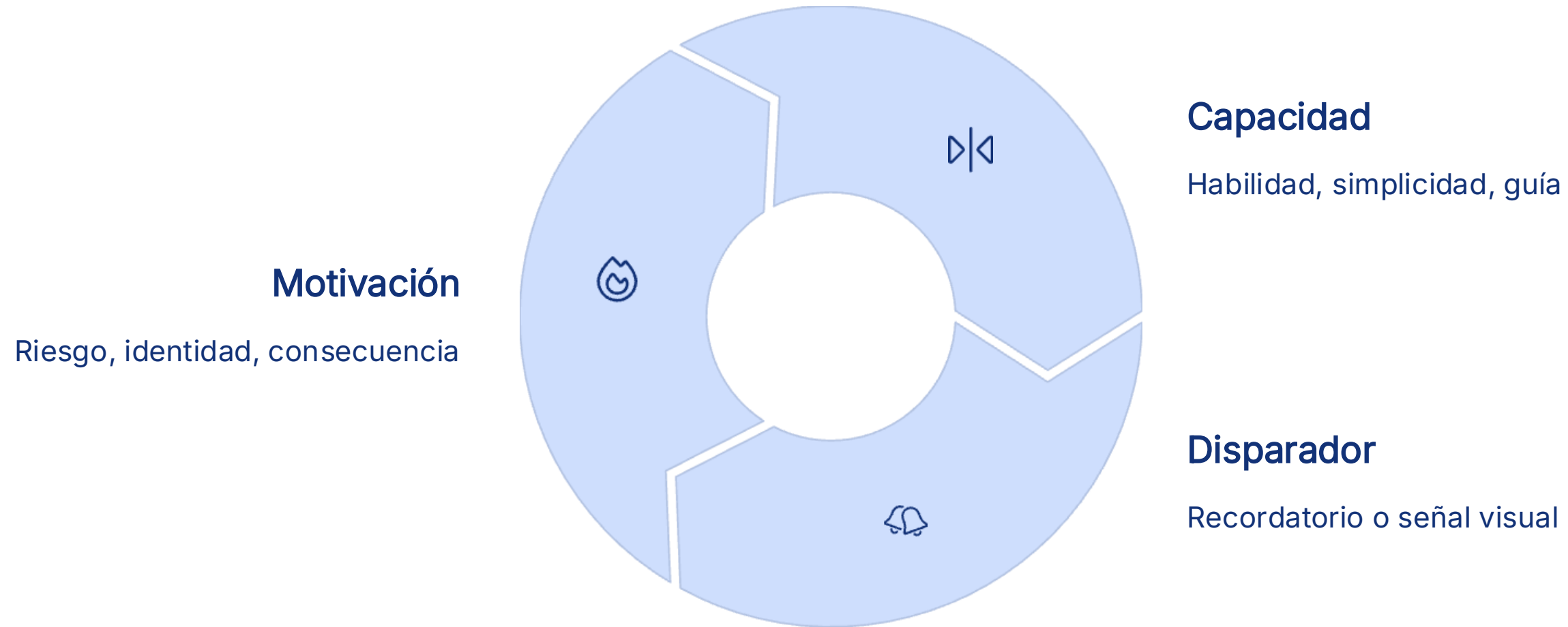


Resultado Esperado del Cambio:

Los colaboradores eliminan correctamente los archivos con datos personales siguiendo las políticas, utilizando los recursos entregados, y manteniendo la práctica de forma sostenida.

Modelo de Fogg – Introducción

$$\text{Behavior} = \text{Motivation} + \text{Ability} + \text{Prompt}$$



El modelo de comportamiento de Fogg establece que para que ocurra un comportamiento deseado, deben coincidir tres elementos: suficiente motivación, capacidad adecuada para realizar la acción y un disparador efectivo que active el comportamiento en el momento oportuno.

Esta fórmula (Comportamiento = Motivación + Capacidad + Disparador) ofrece un marco práctico para diseñar intervenciones que promuevan comportamientos positivos en protección de datos.

Fogg – Ejemplo aplicado

Aplicación del modelo de Fogg

- **Motivación:** Presentación de un caso real donde una fuga de información por un adjunto no cifrado resultó en consecuencias graves para la empresa y el empleado responsable.
- **Capacidad:** Implementación de una plantilla automática que simplifica el proceso de cifrado, reduciendo el esfuerzo necesario para proteger la información.
- **Disparador:** Configuración de un pop-up que aparece automáticamente al detectar que se está adjuntando un archivo potencialmente sensible, recordando la necesidad de cifrado.



Behavior = Motivation + Ability + Prompt

Para que ocurra un comportamiento, deben coincidir estos tres elementos al mismo tiempo:

- **Motivación:** El deseo de hacer la acción.
- **Habilidad:** Qué tan fácil es hacerla.
- **Disparador (Prompt):** El recordatorio o activador en el momento adecuado.

Fogg – Ejemplo “Que los colaboradores eliminen correctamente los archivos con datos personales cuando ya no son necesarios”

MOTIVACION

Haz que el colaborador quiera actuar:

Acciones:

- Mostrar historias reales de consecuencias graves por no eliminar archivos (ej: multas, daño reputacional).
- Resaltar el impacto personal: “Evita sanciones, protege tu equipo, evita estrés innecesario”.
- Asociar la acción con valores positivos: “Ser responsable con los datos = ser un profesional confiable”.

Insight Fogg: No necesitas motivar a todos con miedo. Puedes usar orgullo, sensación de éxito o pertenencia.

HABILIDAD

Facilita la acción al máximo:

Acciones:

- Simplificar el proceso con una guía de 3 pasos para eliminación segura.
- Usar herramientas con “borrado seguro” (por ejemplo, opción en menú contextual del sistema).
- Instrucciones visuales con íconos y ejemplos en una hoja

Insight Fogg: Si la tarea es complicada o ambigua, aunque haya motivación, no ocurrirá.

DISPARADOR

Activa el comportamiento en el momento adecuado:

Acciones:

- Notificación automática del sistema: “Este archivo tiene más de 180 días, ¿deseas eliminarlo según la política?”
- Cartel en el escritorio o firma de correo: “¿Ya revisaste si tu archivo aún es necesario?”
- Campaña de “Día de limpieza digital”: todos eliminan archivos innecesarios al final del mes.

Insight Fogg: Un buen disparador debe estar alineado al contexto y momento preciso.

Nudges – Introducción

Definición

Los nudges o "empujoncitos" son estímulos sutiles que orientan la acción sin imponerla, preservando la libertad de elección mientras se facilita la toma de decisiones favorables.

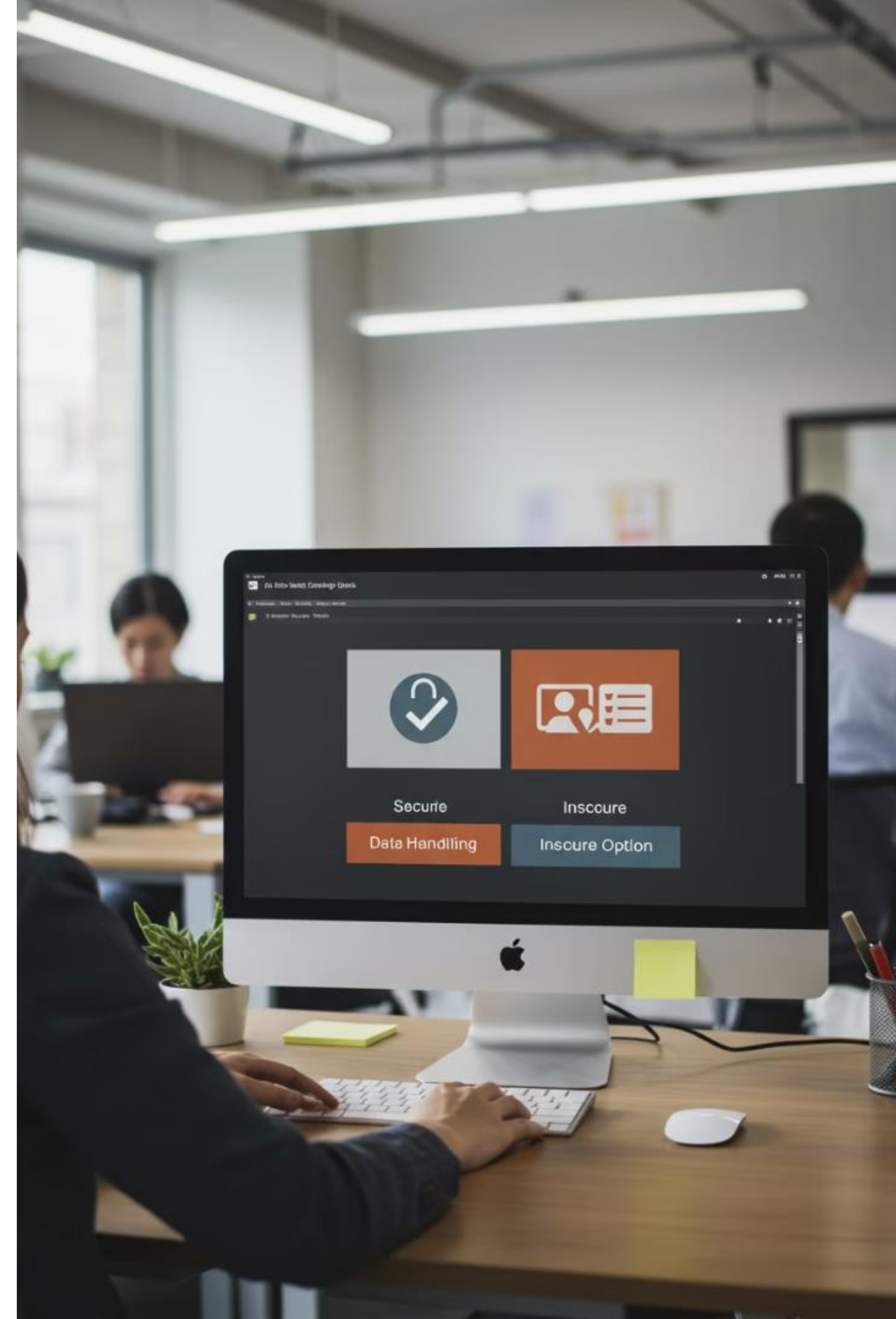
Características

- No son coercitivos
- Modifican el contexto de decisión
- Aprovechan sesgos cognitivos
- Son de bajo costo de implementación

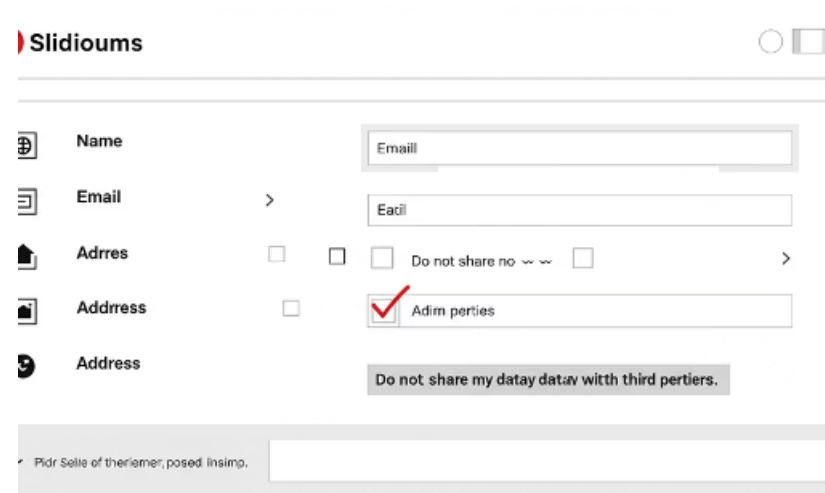
Beneficios en protección de datos

- Reducen la fricción para comportamientos seguros
- Generan menos resistencia que las políticas estrictas
- Pueden adaptarse a diferentes contextos y perfiles

La teoría de los nudges, desarrollada por Richard Thaler y Cass Sunstein, propone que pequeñas intervenciones en el entorno pueden tener un impacto significativo en el comportamiento, sin restringir opciones ni cambiar incentivos económicos.



Ejemplos de nudges en privacidad



Pre-marcar opciones seguras

Configurar por defecto la opción "No compartir datos con terceros" en formularios, aprovechando la tendencia a mantener las opciones preestablecidas mientras se respeta la capacidad de elección del usuario.



Simulador de riesgos

Herramienta interactiva que muestra las posibles consecuencias de enviar datos erróneamente, haciendo tangibles y visibles riesgos que de otro modo podrían parecer abstractos o improbables.



Alertas visuales

Emoji de advertencia que aparece automáticamente cuando se detecta que un dato personal está siendo copiado, creando un momento de pausa y reflexión antes de completar la acción.

Diseño de campañas con nudges

Semana de la privacidad

Evento anual con actividades temáticas que refuerzan la importancia de la protección de datos a través de juegos, concursos y charlas breves, creando un ambiente positivo alrededor del tema.

Correos con historias reales

Comunicaciones periódicas que narran casos verídicos de incidentes de privacidad y sus consecuencias, aprovechando el poder de la narrativa para generar empatía y conciencia.

QR en pantallas con tips breves

Códigos QR ubicados estratégicamente en áreas comunes que dirigen a consejos prácticos sobre protección de datos, facilitando el acceso a información relevante en momentos de espera.

Stickers en dispositivos

Pequeños recordatorios visuales adheridos a laptops, teléfonos y otros dispositivos que promueven hábitos seguros como bloquear pantallas o verificar destinatarios.

Diseño de instrumento para medir la cultura en Protección de Datos

Conocimiento y Comprensión Normativa

- ¿Conoces qué es un dato personal y un dato sensible?
- ¿Conoces las obligaciones que tiene la empresa respecto al tratamiento de datos personales?
- ¿Sabes qué derechos tienen los titulares de los datos?

Actitud hacia la Protección de Datos

- ¿Consideras importante proteger los datos personales de clientes y colaboradores?
- ¿Te preocupa que se vulneren los derechos de privacidad de las personas?
- ¿Sientes que la protección de datos es parte de tu rol laboral?

Comportamiento y Prácticas Cotidianas

- ¿Revisas que los datos que recolectas tienen una finalidad legítima?
- ¿Compartes datos personales solo con personas autorizadas?
- ¿Eliminas o anonimizas los datos cuando ya no son necesarios?

Escala Likert – 1 a 5

No estoy de acuerdo –estoy muy de acuerdo

Uso de Herramientas y Canales

- ¿Sabes cómo reportar un incidente de privacidad?
- ¿Conoces el canal para que un titular pueda ejercer sus derechos?
- ¿Te han enseñado cómo trabajar con herramientas seguras (e.g. cifrado, gestión de contraseñas)?

Encuesta de madurez cultural

Nivel	Descripción
1. Desconectados	No conocen la normativa ni su rol en la protección de datos. Actúan sin considerar implicaciones de privacidad.
2. Reactivos	Actúan solo ante supervisión o auditoría. Cumplen por obligación, no por convicción.
3. Activos o Comprometidos	Aplican medidas proactivamente. Entienden la importancia y buscan mejorar prácticas.
4. Embajadores o Champions	Promueven, educan y corrigen a otros. Son referentes y agentes de cambio en la organización.

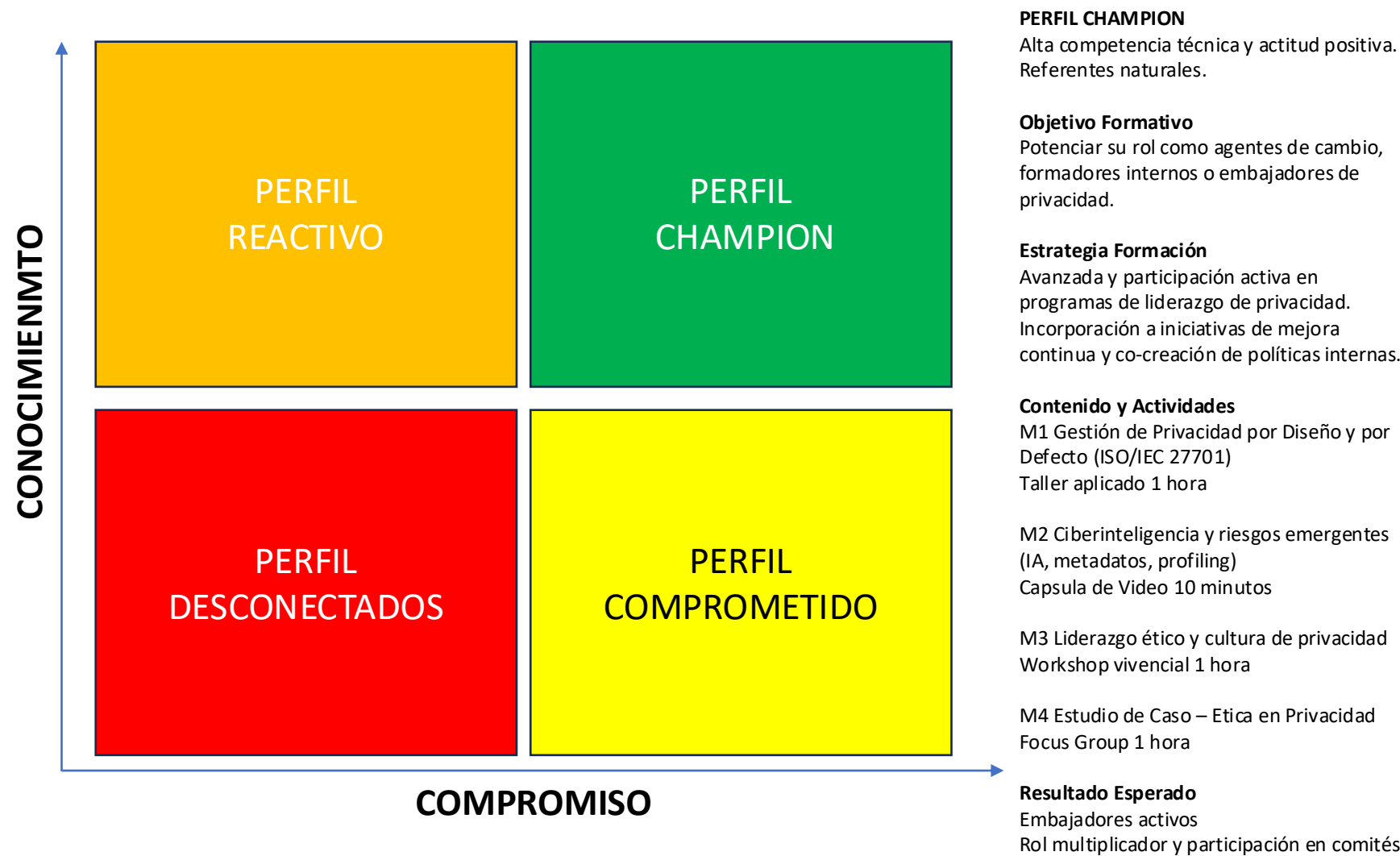
La encuesta de madurez cultural permite diagnosticar el estado actual de la organización respecto a la protección de datos, identificando áreas de fortaleza y oportunidad. Este diagnóstico es fundamental para diseñar intervenciones efectivas y medir el progreso a lo largo del tiempo.



Encuesta de madurez cultural

En 2023, la Agencia Española de Protección de Datos (AEPD) recibió más de 15.000 reclamaciones, y más del 60% de los incidentes reportados se originaron por errores humanos o prácticas inseguras dentro de las organizaciones.

Esto no ocurre solo en Europa. También en Chile, con la nueva Ley de Protección de Datos, el riesgo reputacional y normativo es más real que nunca.



Interpretación de resultados

Análisis por unidad

Comparación de resultados entre diferentes departamentos o equipos, identificando áreas con mayor o menor madurez cultural en protección de datos.

Este análisis permite personalizar intervenciones según las necesidades específicas de cada unidad, optimizando recursos y maximizando impacto.

Evolución temporal

Seguimiento de resultados año tras año para evaluar la efectividad de las intervenciones implementadas y ajustar estrategias según sea necesario.

La comparación longitudinal revela tendencias y patrones que pueden no ser evidentes en una evaluación puntual, proporcionando una visión más completa del cambio cultural.

Identificación de clústeres

Agrupación de colaboradores según su nivel de madurez cultural, permitiendo diseñar intervenciones específicas para cada segmento.

Este enfoque reconoce que diferentes grupos requieren distintos tipos de apoyo para avanzar en su compromiso con la protección de datos.

Diseño de un plan de cambio cultural



Diagnóstico

Evaluación del estado actual mediante encuestas, entrevistas y observación de comportamientos relacionados con protección de datos.



Objetivos por cluster

Definición de metas específicas para cada segmento identificado, considerando su nivel de madurez y rol en la organización.



Acciones con metodología

Diseño de intervenciones basadas en ADKAR, Fogg o Nudges, seleccionando el enfoque más adecuado para cada objetivo.



Recursos y responsables

Asignación clara de responsabilidades y recursos necesarios para implementar cada acción del plan.



Métricas

Establecimiento de indicadores clave (KPI, KRI) y mecanismos para evaluar la percepción y efectividad de las intervenciones.

Acciones específicas por cluster



Alta dirección

Sesiones ejecutivas sobre riesgos reputacionales y legales, dashboard de indicadores clave de protección de datos, y participación visible en eventos de privacidad para modelar comportamientos deseados y demostrar compromiso desde el liderazgo.



RRHH

Integración de criterios de privacidad en procesos de selección y evaluación, desarrollo de programas de onboarding con énfasis en protección de datos, y diseño de reconocimientos para comportamientos ejemplares que refuercen la cultura deseada.



TI y ciberseguridad

Implementación de controles técnicos que faciliten comportamientos seguros, desarrollo de materiales de capacitación accesibles, y creación de canales efectivos para reportar y gestionar incidentes de seguridad de datos.

Más acciones específicas por cluster

Front office

El personal que interactúa directamente con clientes requiere intervenciones enfocadas en la protección de datos durante la atención al público:

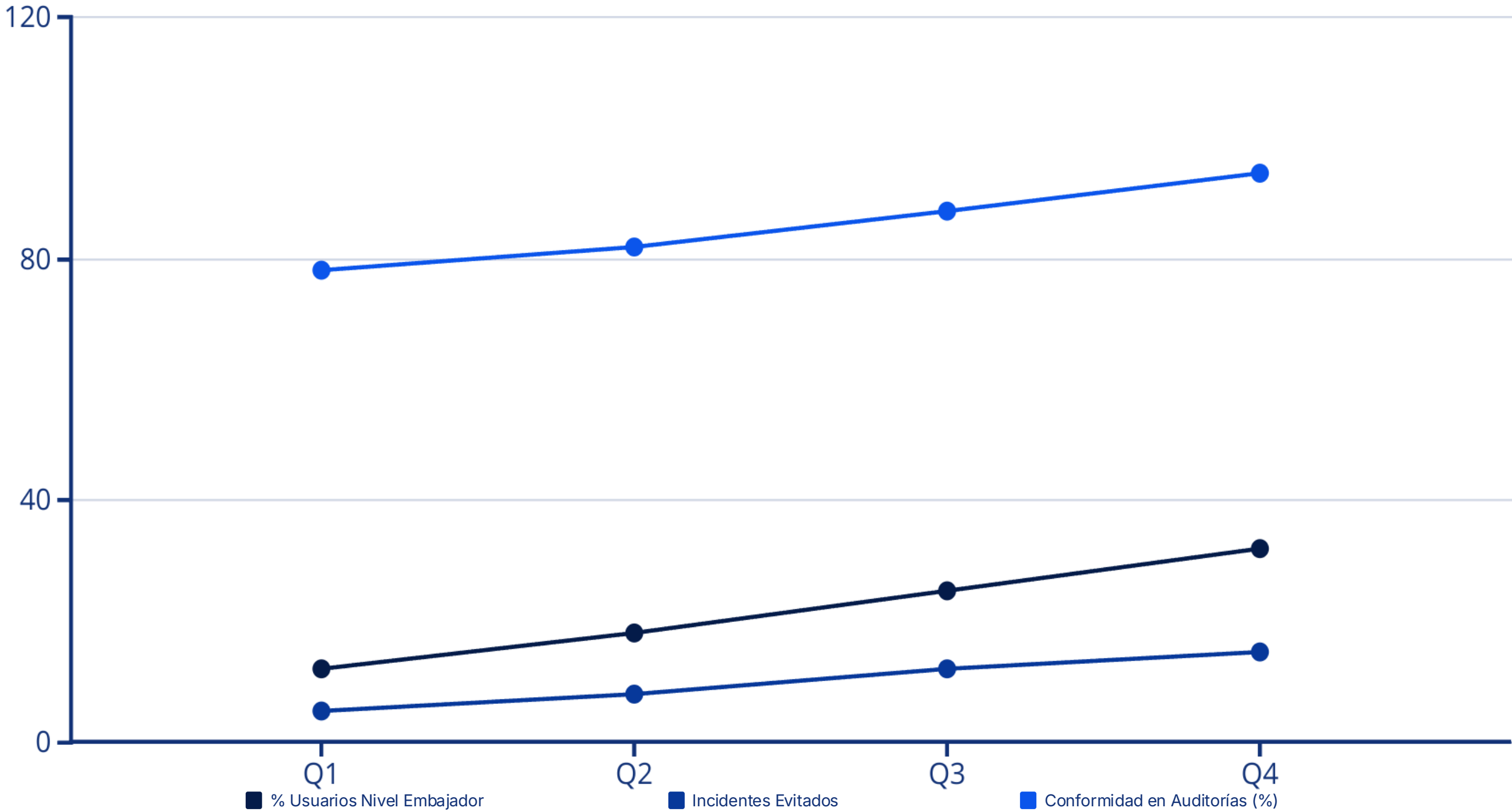
- Guiones para solicitar y verificar información personal de manera segura
- Simulaciones de situaciones complejas (clientes insistentes, urgencias)
- Recordatorios visuales en puestos de atención
- Reconocimiento a quienes detectan intentos de ingeniería social

Proveedores

Los terceros que procesan datos personales en nombre de la organización también deben ser incluidos en el plan de cultura:

- Cláusulas contractuales con requisitos específicos de protección
- Capacitación obligatoria antes de acceder a sistemas
- Auditorías periódicas de cumplimiento
- Canales de comunicación para reportar incidentes

Indicadores de evaluación



Teoría Moral

Reflexión sistemática sobre las afirmaciones
éticas y las razones de las mismas

- **No entrega fórmulas**
- **Ayuda a Reconocer la forma de un problema ético**
- **No sustituye nuestra conciencia moral**
- **No reemplaza asesoría o consejos de expertos en la materia**

El **principialismo** es una perspectiva ética que proporciona principios normativos específicos para guiar la toma de decisiones éticas, especialmente en el contexto de la atención médica y la bioética. Estos principios normativos son la autonomía, la beneficencia, la no maleficencia y la justicia.

Teorías Morales Subyacentes básicas, como el utilitarismo

- **Deontología:** Se enfoca en la moralidad de las acciones en sí mismas, independientemente de sus consecuencias.
- **Consecuencialismo:** Evalúa la moralidad de las acciones en función de sus resultados o consecuencias. Ejemplos incluyen el utilitarismo.
- **Ética de la virtud:** Se centra en la formación del carácter y en ser una persona virtuosa.

▪ Definición de Principios

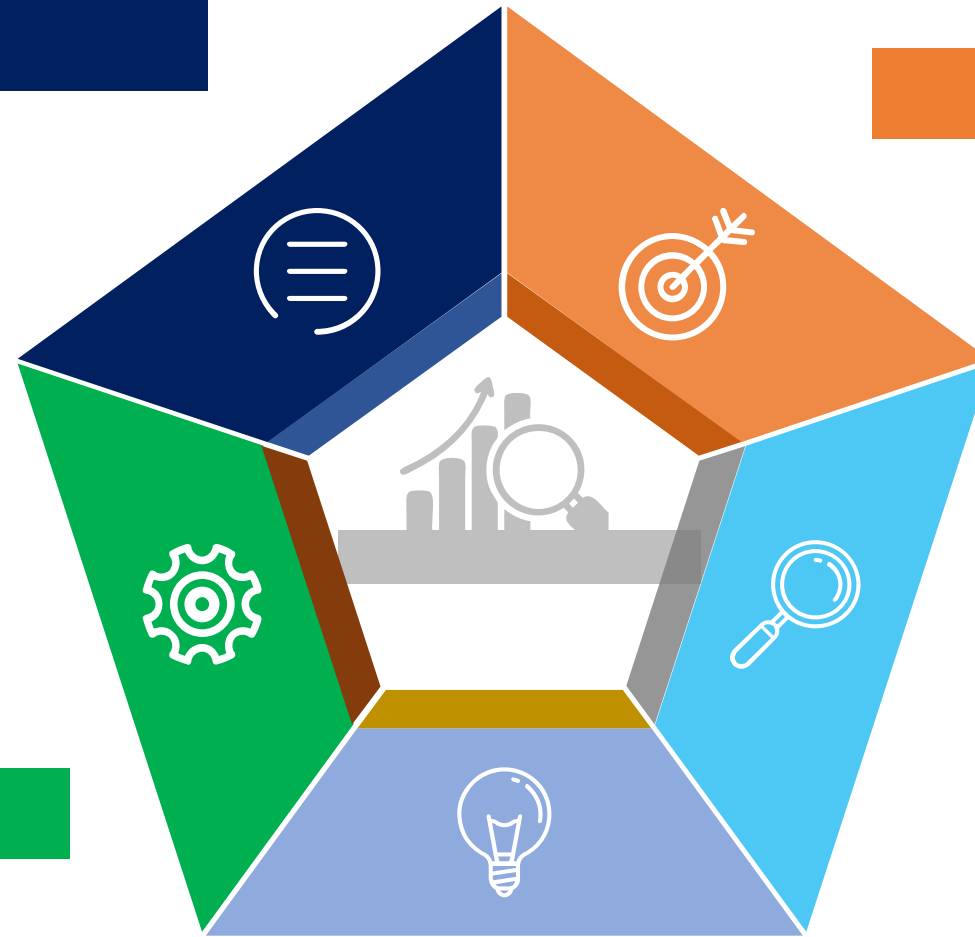
BENEFICIENCIA

NO MALIFICENCIA

AUTONOMIA

EXPLICABILIDAD

JUSTICIA



BENEFICIENCIA

Las tecnologías de ciberseguridad se deben usar para beneficiar a los seres humanos, promover el bienestar humano y mejorar la vida en general

- Promover el bien común
- Proteger la privacidad
- Beneficios financieros
- Beneficios reputacionales
- Beneficios de conectividad
- Confianza más fortalecida

NO MALEFICIENCIA

Las tecnologías de ciberseguridad no se deben usar para dañar intencionalmente a los seres humanos, o para empeorar nuestras vidas en general

- **Violaciones de Privacidad**
- **Daño Financiero**
- **Daño Físico**
- **Daño Sicológico**
- **Daño de sistemas**
- **Daño de datos**
- **Daño reputacional**

AUTONOMIA

Las tecnologías de ciberseguridad se deben usar de manera que se respete la autonomía humana. Los seres humanos deberían poder tomar decisiones informadas por sí mismos sobre cómo se utiliza esa tecnología en sus vidas

- **Consentimiento Informado**
- **Acceso y Control de Datos**
- **Configuraciones de Privacidad**
- **Propiedad**
- **Respeto por las personas**
- **Relacionamiento**

JUSTICIA

Las tecnologías de ciberseguridad se deben usar para promover la equidad, la igualdad y la imparcialidad. No se debe utilizar para discriminar injustamente, socavar la solidaridad o impedir la igualdad de accesos

- **Democracia**
- **Eliminación de Sesgos**
- **Accesabilidad & Usabilidad**
- **Procedimientos Justos**
- **Derechos (incluida la privacidad)**
- **AutoDefensa**

EXPLICABILIDAD

Las tecnologías de ciberseguridad se deben usar de manera inteligible, transparente y comprensible, y también debe quedar claro quién es responsable de su uso

- Responsabilidad
- Transparencia (políticas de privacidad)
- Responsabilidad de uso de IA
- Responsabilidad para proteger sistemas y datos
- Desarrollo profesional & Diligencia

EJEMPLO PRACTICO

BENEFICIENCIA

Beneficencia

“Actuar siempre en beneficio del titular de los datos”

Aplicación en protección de datos:

- Diseñar los sistemas y procesos para que protejan proactivamente la privacidad de las personas (privacy by design).
- Utilizar los datos para mejorar servicios, ofrecer experiencias más seguras o facilitar trámites al titular.

Ejemplo práctico:

La empresa decide anonimizar los datos de salud de sus clientes para realizar análisis estadísticos, priorizando la utilidad colectiva sin comprometer la identidad de las personas.

EJEMPLO PRACTICO

JUSTICIA

“Tratar a todas las personas de manera equitativa y sin discriminación en el uso de sus datos”

Aplicación en protección de datos:

- Evitar que los algoritmos de decisión (como scoring crediticio) perpetúen sesgos o discriminación.
- No usar los datos para excluir, estigmatizar o segmentar de forma injusta a grupos sociales.

Ejemplo práctico:

El modelo de evaluación crediticia de la empresa es auditado regularmente para asegurar que no discrimina por edad, género o ubicación geográfica.

Caso de Análisis: Protegiendo la Confianza en Financor

Financor S.A. es una institución financiera chilena con más de 15 años en el mercado, dedicada al otorgamiento de créditos de consumo, tarjetas de crédito y productos de inversión digital. Con más de 1.200 colaboradores, la empresa enfrenta el desafío de adaptar su cultura organizacional a la nueva Ley de Protección de Datos Personales (Ley 21.096).

El Directorio ha solicitado a la Unidad de Cumplimiento iniciar un diagnóstico de la cultura organizacional en protección de datos, para posteriormente diseñar un plan de acción transversal que garantice el cumplimiento normativo y fortalezca la confianza de sus clientes.



Objetivo del Caso



Aplicar Encuesta

Implementar una encuesta de cultura organizacional en protección de datos para evaluar el estado actual de la empresa.



Analizar Resultados

Examinar los datos obtenidos para identificar brechas y oportunidades de mejora en la gestión de datos personales.



Proponer Plan de Acción

Desarrollar un plan segmentado por área o perfil de riesgo que aborde las deficiencias identificadas.



Resolver Dilema Ético

Analizar y proponer soluciones a un dilema ético relacionado con el tratamiento de datos personales.



Encuesta



La encuesta de diagnóstico de cultura de protección de datos está diseñada para evaluar de manera integral el estado actual de la organización. Dividida en 5 focos temáticos, cada pregunta se responde en una escala de Likert donde 1 representa "Totalmente en desacuerdo" y 5 "Totalmente de acuerdo".

La puntuación máxima posible es de 225 puntos (45 preguntas x 5 puntos), lo que permitirá establecer una línea base para medir el progreso futuro y comparar diferentes áreas de la organización.

Foco 1: Conocimiento y Normativas

Comprensión Conceptual

- Entendimiento de datos personales
- Distinción entre dato personal y sensible
- Conocimiento de la nueva ley

Políticas Internas

- Familiaridad con políticas de privacidad
- Conocimiento del DPO
- Acceso a documentación relevante

Gestión Operativa

- Conocimiento de datos recolectados
- Plazos de conservación
- Evaluación de Impacto en la Privacidad

Este primer foco evalúa el nivel de conocimiento teórico y normativo que poseen los colaboradores sobre protección de datos. Las nueve preguntas buscan determinar si los empleados comprenden conceptos básicos, conocen la legislación vigente y están familiarizados con las políticas internas de Financor relacionadas con la privacidad de datos.

Un buen resultado en este foco indicaría que existe una base sólida de conocimiento, mientras que puntuaciones bajas señalarían la necesidad de reforzar la capacitación en aspectos fundamentales.

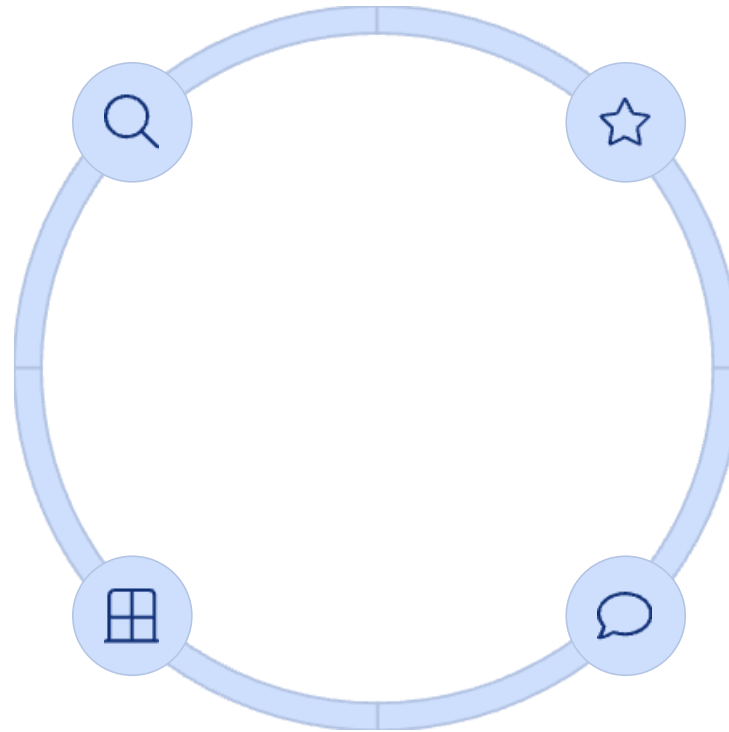
Foco 2: Actitud y Ética

Responsabilidad Personal

Reconocimiento del rol individual en la protección de datos y compromiso con prácticas éticas.

Valores Personales

Valoración de la transparencia y reconocimiento de la privacidad como derecho fundamental.



Comportamiento Ético

Actitud hacia el tratamiento adecuado de datos y disposición para reportar irregularidades.

Cultura Organizacional

Percepción sobre la integración de la privacidad en los valores de la empresa.

El segundo foco examina las actitudes y valores éticos de los colaboradores respecto a la protección de datos. Se evalúa si los empleados consideran la privacidad como parte integral de su responsabilidad laboral y si actúan conforme a principios éticos al manejar información personal.

Este componente es crucial porque refleja la predisposición de los colaboradores hacia comportamientos que favorecen la protección de datos, más allá del mero cumplimiento normativo.

Foco 3: Práctica y Comportamiento



Verificación de Legitimidad

Revisar que el uso de los datos sea legítimo y compartirlos solo con personas autorizadas.



Almacenamiento Seguro

Utilizar herramientas seguras y contraseñas robustas para proteger la información.



Gestión del Ciclo de Vida

Eliminar datos cuando ya no son necesarios y borrarlos antes de reutilizar archivos.



Seguimiento de Protocolos

Adherirse a los procedimientos internos y reportar incidentes de seguridad.

El tercer foco evalúa las prácticas concretas y comportamientos habituales de los colaboradores en el manejo diario de datos personales. Mientras que el foco anterior medía actitudes, este examina acciones específicas que demuestran un compromiso real con la protección de datos.

Las preguntas abordan desde la verificación de la legitimidad del uso de datos hasta el seguimiento de protocolos de seguridad, pasando por prácticas de almacenamiento seguro y gestión adecuada del ciclo de vida de la información.

Foco 4: Uso de Canales y Gestión de Incidentes



Conocimiento de canales de reporte

Familiaridad con mecanismos para reportar brechas



Gestión de derechos ARCO

Capacidad para atender solicitudes de clientes



Acceso a soporte y formación

Disponibilidad de recursos de apoyo y capacitación

Este foco evalúa el conocimiento y uso de los canales establecidos para la gestión de incidentes relacionados con datos personales. Se examina si los colaboradores saben cómo reportar una brecha de seguridad, conocen los canales para ejercer derechos ARCO (Acceso, Rectificación, Cancelación y Oposición) y saben dónde encontrar apoyo en temas de privacidad.

También se evalúa la formación recibida en los últimos 12 meses, un indicador clave del compromiso organizacional con la capacitación continua en protección de datos. Este foco es esencial para determinar la efectividad de los mecanismos de respuesta ante incidentes.

Foco 5: Percepción Organizacional y Gobernanza



El quinto y último foco evalúa la percepción de los colaboradores sobre el compromiso organizacional con la protección de datos y la efectividad de la gobernanza en esta materia. Se examina si los empleados consideran que la empresa se preocupa activamente por la privacidad, si la jefatura fomenta una cultura de protección de datos y si existen campañas frecuentes de sensibilización.

También se evalúa la transparencia de la empresa, la justificación ética de las decisiones sobre datos y la integración de la privacidad en los objetivos estratégicos. Este foco es fundamental para determinar si existe un liderazgo efectivo en materia de protección de datos y si la cultura organizacional respalda las prácticas adecuadas.

Dilema Ético para Resolver



Durante la aplicación de la encuesta, se descubrió que una unidad comercial estaba utilizando una base de datos histórica (más de 7 años de antigüedad) comprada a un tercero para hacer ofertas a clientes sin haber actualizado el consentimiento. Este caso presenta un dilema ético significativo que debe abordarse considerando los principios fundamentales de la ética en el tratamiento de datos.

Los estudiantes deben proponer al menos tres medidas correctivas inmediatas y una acción preventiva de largo plazo, fundamentando sus decisiones en los principios éticos mencionados.

Plan de Acción

Identificación de Brechas

P1. Analizar los resultados de la encuesta para detectar áreas de riesgo por unidad o perfil de cargo, estableciendo prioridades de intervención basadas en evidencia.

A partir del análisis de la encuesta, los estudiantes deberán identificar las principales brechas o focos de riesgo por unidad o perfil de cargo. Esta segmentación permitirá diseñar intervenciones específicas que maximicen su efectividad y optimicen los recursos disponibles.

El plan de acción debe estructurarse en cinco ejes complementarios: formación segmentada según necesidades específicas, intervenciones conductuales como "nudges", mejoras tecnológicas o de procesos, reforzamiento del canal de incidentes, y establecimiento de métricas para seguimiento y evaluación continua.

Diseño de Estrategia

P2. Desarrollar un plan de acción con 5 ejes estratégicos que aborden las deficiencias identificadas, considerando las particularidades de cada área de la organización, mensajes e intervenciones a ejecutar

Implementación

P3. Identifique 2 comportamientos a cambiar y desarrolle las acciones según la metodología ADKAR y NUDGES

P4. Identifique y explique cómo abordaría el problema ético

Rúbrica de Evaluación

Criterio	Descripción	Puntaje Máximo
Análisis de Comportamiento	Interpreta correctamente los datos, identifica tendencias, brechas por unidad y perfiles de riesgo. Usa métricas y visualizaciones relevantes.	8
Diseño del Plan de Acción	Propone acciones alineadas a los hallazgos y principios de gobernanza. Identifica comportamientos a cambiar y utiliza metodologías enseñadas en clases	8
Resolución del Dilema Etico	Aborda todos los principios y propone soluciones razonadas.	5
Redacción, Claridad y Presentación	Presentación clara, profesional y estructurada.	2
Creatividad y aplicabilidad	Propone ideas innovadoras y aplicables a una empresa real.	2

La evaluación del caso se realizará mediante una rúbrica que contempla cinco criterios fundamentales, con un puntaje total máximo de 25 puntos. Se valorará especialmente la capacidad de análisis de los resultados de la encuesta, la coherencia y viabilidad del plan de acción propuesto, y la profundidad en la resolución del dilema ético.

También se considerará la claridad en la presentación de las ideas y la creatividad en las soluciones propuestas, siempre que estas sean aplicables en el contexto de una empresa financiera real como Financor.



IMPULSA TU FUTURO CON LA CALIDAD UCHILE

Facultad de Economía y Negocios:

Diagonal Paraguay 257, Piso 6, Santiago.

Campus oriente: Av. Nueva Los Leones 0222, Providencia.



UEjecutivos



@uejecutivos



uejecutivos



UEjecutivos FEN U. de
Chile



Detalle de la Encuesta Aplicada

A continuación, se presenta la **encuesta de diagnóstico de cultura de protección de datos**, dividida en 5 focos temáticos. Cada pregunta se responde en una escala de Likert de 1 (Totalmente en desacuerdo) a 5 (Totalmente de acuerdo). La puntuación máxima es de **225 puntos (45 x 5)**. Se deberá calcular un **puntaje promedio** por foco y por perfil de colaborador.

Foco 1: Conocimiento y normativas (9 preguntas)

1. Sé lo que se entiende por dato personal.
2. Puedo distinguir entre dato personal y dato sensible.
3. Conozco la nueva Ley de Protección de Datos.
4. Conozco las políticas internas sobre privacidad.
5. Sé quién es el DPO de la organización.
6. He leído o recibido la política de privacidad interna.
7. Sé qué datos recolecta mi unidad.
8. Conozco los plazos de conservación de datos.
9. Sé qué es una Evaluación de Impacto en la Privacidad (PIA).

Foco 2: Actitud y ética (9 preguntas)

10. Considero que proteger los datos personales es parte de mi rol.
11. Me preocupo por no acceder a datos sin autorización.
12. Actúo con ética al tratar datos de clientes o colegas.
13. Informo si veo un tratamiento indebido de datos.
14. Siento que la privacidad es parte de la cultura empresarial.
15. Me incomoda ver malas prácticas con datos personales.
16. Me esfuerzo por no retener datos más de lo necesario.
17. Valoro la transparencia en el uso de datos.
18. Veo la privacidad como un derecho, no solo un deber legal.

Foco 3: Práctica y comportamiento (9 preguntas)

19. Reviso que el uso de los datos sea legítimo.
20. Solo comparto datos con quienes están autorizados.
21. Elimino los datos cuando ya no son necesarios.
22. Uso herramientas seguras para el almacenamiento.
23. Uso contraseñas seguras y las actualizo.
24. No envío datos personales por canales no cifrados.
25. Informo si detecto una fuga o pérdida de datos.
26. Sigo los protocolos internos para gestionar datos.
27. Borro datos antes de reutilizar archivos o formularios.

Foco 4: Uso de canales y gestión de incidentes (9 preguntas)

1. Sé cómo reportar una brecha de seguridad.
2. Conozco los canales para ejercer derechos ARCO.
3. Puedo identificar cuándo debo hacer un PIA.
4. Sé qué hacer si un cliente solicita eliminar sus datos.
5. Sé dónde encontrar apoyo o consulta sobre privacidad.
6. Conozco los pasos ante un incidente de phishing.
7. Recibo alertas o recordatorios sobre buenas prácticas.
8. Conozco el canal para sugerencias o denuncias.
9. He recibido formación específica en los últimos 12 meses.

Foco 5: Percepción organizacional y gobernanza (9 preguntas)

1. La empresa se preocupa activamente de la privacidad.
2. La jefatura fomenta la cultura de protección de datos.
3. Hay campañas frecuentes de sensibilización.
4. Se valoran los reportes de incidentes o brechas.
5. Existe una gobernanza clara de protección de datos.
6. La empresa actúa con transparencia en esta materia.
7. Las decisiones sobre datos son éticamente justificadas.
8. Se promueve la privacidad como ventaja competitiva.
9. La privacidad es parte de los objetivos estratégicos.